
Mariana BS - Cybersecurity Engineer
GUIA COMPLETO DE ESTUDOS
Analista SOC N1
WINDOWS TAMBÉM CONTA HISTÓRIA
Processos e Serviços
Processos
Serviços
Desempenho
Rede
Usuários
Nome
PID
Status
Usuário
svchost.exe 1260 Running SYSTEM
explorer.exe 5320 Running Usuario
powershell.exe 7348 Running Usuario
wmiPrvSE.exe 4120 Running NETWORK...
lsass.exe 828 Running SYSTEM
winlogon.exe 656 Running SYSTEM
Eventos do Windows
Nível
Data e Hora
Fonte
ID
Categoria
Erro 10/24 10:15:23 Security 4625 Logon
Aviso 10/24 10:14:11 Sysmon 1 Process
Info 10/24 10:13:02 Microsoft-Windows-PowerShell 4104 ScriptBlock
Info 10/24 10:11:45 Security 4688 Process
Info 10/24 10:10:01 Microsoft-Windows-TaskScheduler 106 Task
Info 10/24 09:58:12 Microsoft-Windows-WMI 5857 WMI Activity
Registro do Windows
HKEY_LOCAL_MACHINE
SOFTWARE
Microsoft
Windows
CurrentVersion
Run
RunOnce
Services
Policies
Explorer
PowerShell
PS C:\> Get-Process
PS C:\> Get-Service
PS C:\> Get-ScheduledTask
PS C:\> Get-EventLog -LogName Security
PS C:\> Get-WmiObject Win32_Process
PS C:\> Get-ItemProperty
HKLM:\SOFTWARE\...\Run
WMI e Consultas
WMI
Get-WmiObject Win32_ComputerSystem
Name : ESTACAO01
Domain : EMPRESA.LOCAL
Manufacturer : Dell Inc.
Model : OptiPlex 7010
Tarefas Agendadas
Nome
Status
Última Execçã
\Microsoft\Windows\... Pronto 10/24 02:00
\UpdateCheck Pronto 10/24 01:00
\Backup Pronto 10/23 23:00
\ClienteXYZ Pronto 10/24 04:15
\Operacao Em execução 10/24 10:10
Autenticaiação no Windows
Logon 4624 / 4625
Kerberos
NTLM
Grupos e privilégios
Investigação e Linha do Tempo
Execução de processo
Comando PowerShell
Modificação no Registro
Criação de tarefa
Conexão de rede
SOC N1
EVENT ID SEM CONTEXTO É SÓ NÚMERO
PROCESSOS E SERVIÇOS
REGISTRO DO WINDOWS
EVENT VIEWER E EVENT IDS
POWERSHELL
WMI
TAREFAS AGENDADAS
AUTENTICAÇÃO
SYSMON
TRIAGEM E INVESTIGAÇÃO
EVIDÊNCIA NÃO MENTE
Plano de Estudo – Módulo 3
Entender processos e serviços
Ler e interpretar eventos do Windows
Analisar Registro, tarefas e WMI
Usar PowerShell e Sysmon
Reconstruir linha do tempo
Fazer triagem baseada em fatos
ADMIN TAMBÉM DEIXA RASTRO
Módulo 3 — Windows para SOC
Processos, serviços, Registro, tarefas, Powershell, WMI e autenticação.
Como transformar eventos do Windows em investigação.
O que você vai conseguir fazer:
Reconstruir uma linha do tempo a partir de evidências do Windows.
Diferenciar administração legítima de atividade suspeita.
Usar Event Viewer, PowerShell e Sysmon com responsabilidade.
Escrever uma triagem N1 baseada em fatos.
Público:
Iniciante que quer trabalhar com evidências reais, não só decorar Event IDs.
Pré-requisitos:
Módulo 1 (Redes) e Módulo 2 (Arquitetura de Ambientes Corporativos).

Sumário

Módulo 3: Windows para SOC 4
3.1 Objetivo e modelo mental 4
As seis perguntas que acompanham qualquer alerta 4
3.2 O que acontece dentro do Windows 5
32 bits, 64 bits e caminhos que confundem 5
3.3 Processos, linhas de comando e árvores 6
Event ID 4688: criação de processo 6
3.4 Serviços e drivers 7
3.5 Registro do Windows 8
3.6 Tarefas agendadas 9
Persistência: serviço, tarefa e chave Run lado a lado 10
3.7 PowerShell e scripts 11
3.8 WMI e execução remota 12
3.9 Autenticação, RDP e SMB 13
Tipos de logon que aparecem todo dia 13
3.10 Event Viewer e canais de log 15
O relógio merece uma investigação própria 15
3.11 Sysmon e visibilidade de endpoint 15
3.12 Método de triagem Windows: do alerta à decisão 16
3.13 Três mini-casos de plantão 17
Caso 1: "Word abriu PowerShell" 18
Caso 2: "Serviço instalado em servidor" 18
Caso 3: "Conta privilegiada entrou por RDP" 18
3.14 Laboratório guiado: estação de análise Windows 18
Preparação 18
Atividade A: árvore de processo benigna 19
Atividade B: serviço e tarefa legítimos 19
Atividade C: linha do tempo 19
Atividade D: exercício de ticket 19
Laboratório E: diferenciar tentativa de sucesso 19
Laboratório F: inventário de autoexecução sem alterar nada 20
Laboratório G: visibilidade e perda de dados 20
Laboratório H: correlação de rede por processo 20
Laboratório I: construa e revise um ticket 20
3.15 Consultas e comandos para ter à mão 20
3.16 Erros comuns e falsos positivos 21
Falsos positivos: sinais e como confirmar 21
Quando escalar imediatamente 22

Fechamento do Módulo 3 23
Exercícios de fixação 23
Entrevista: resposta fraca x resposta boa 23
Checklist de domínio 25
Checklist de prontidão operacional 25
Resumo do módulo 25
Respostas comentadas 26
Próximo módulo 26

Módulo 3: Windows para SOC

3.1 Objetivo e modelo mental

No Módulo 2 você aprendeu onde ficam os ativos, os pontos de passagem e os logs. Agora vamos entrar em uma estação e em um servidor Windows. Um alerta dizendo "PowerShell suspeito" só faz sentido depois de responder: quem executou, qual processo iniciou, em qual máquina, sob qual contexto e o que aconteceu depois.

- Identificar processo, PID, PPID, caminho, usuário, integridade e linha de comando.
- Entender serviços, tarefas agendadas, Registro e WMI como mecanismos de administração e possíveis pontos de persistência.
- Reconhecer eventos de autenticação e acesso remoto sem confundir tentativa com sucesso.
- Ler logs do Windows e Sysmon, considerando pré-requisitos de auditoria e cobertura.
- Correlacionar processo → rede → identidade → arquivo → resposta do controle.
- Registrar lacunas de telemetria e escalar somente com evidência e impacto.

> 🎯 **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Windows não é apenas uma lista de Event IDs. É um sistema de objetos, contas, processos e permissões. Um mesmo comando pode ser benigno em um servidor de automação e muito suspeito em um notebook do financeiro.

As seis perguntas que acompanham qualquer alerta

Pergunta	Evidência a buscar
O que executou?	Imagem, caminho, hash, assinatura, comando
Quem iniciou?	Usuário, logon ID, token, origem, conta de serviço
De onde veio?	Processo pai, arquivo original, e-mail, browser, tarefa, serviço
O que mudou?	Arquivo, Registro, serviço, tarefa, privilégio
Com quem falou?	DNS, conexões, destino, proxy/firewall, processo
Qual impacto?	Execução confirmada, persistência, lateralidade, dados e criticidade

> 🎯 **O QUE UM N1 REALMENTE PRECISA SABER: Princípio da investigação**
>
> Processo inesperado é indício; execução observada é fato; impacto exige evidência própria. O Windows não fornece uma confissão pronta. Fornece rastros para juntar.

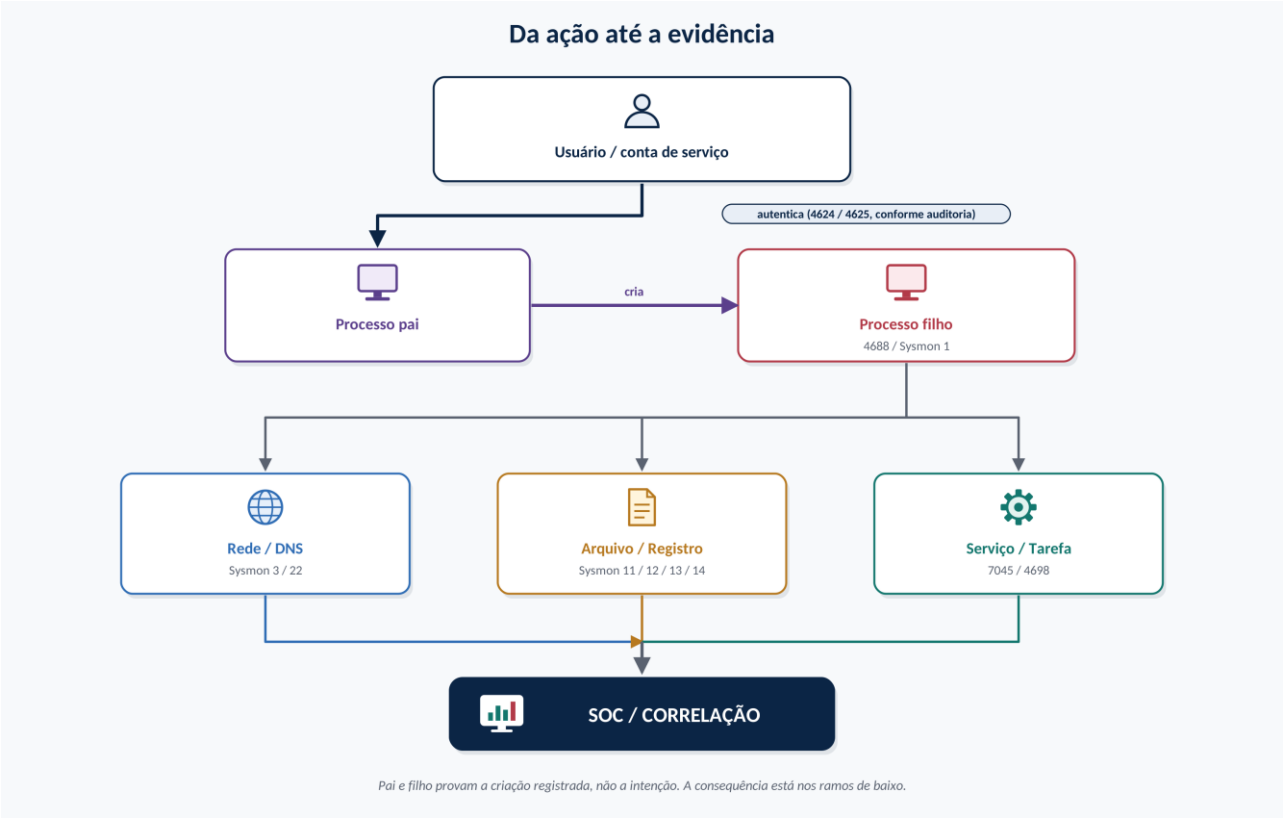


Figura 3.1: Da ação até a evidência

Como ler: uma relação pai-filho prova a criação registrada, não a intenção. Para explicar consequência, busque alteração de arquivo, atividade de rede e relação de identidade no mesmo host e intervalo.

3.2 O que acontece dentro do Windows

O kernel gerencia recursos e isolamento; os processos executam código em espaços de memória separados; threads são unidades de execução dentro dos processos; serviços fazem trabalhos em segundo plano; contas e tokens determinam permissões. O N1 normalmente não depura kernel: ele entende o suficiente para saber o que cada telemetria realmente comprova.

Conceito	Exemplo	Por que importa ao SOC
Processo	`powershell.exe`, `winword.exe`	Quem executou e com quais argumentos
Thread	Fluxo de execução de um processo	Injeção e comportamento anômalo podem ocorrer em threads
PID / PPID	PID 5132 / pai 2816	Ligar filho ao pai; PIDs são reutilizados
Token de acesso	Usuário, grupos, integridade	Distinguir usuário comum de privilégio elevado
Sessão de logon	Logon ID, tipo, origem	Correlacionar autenticação e processo
Serviço	Spooler, WinRM, agente EDR	Persistência, execução recorrente e mudança de configuração
Registro	Run, Services, políticas	Configuração e possíveis mecanismos de execução automática

32 bits, 64 bits e caminhos que confundem

Em Windows 64 bits, `System32` normalmente contém binários 64 bits; `SysWOW64` contém componentes 32 bits. A nomenclatura engana. Muitos binários assinados pela Microsoft podem ser abusados; assinatura válida e caminho esperado ajudam a investigar, mas não encerram o caso.

> **NA VIDA REAL**
>
> O alerta trouxe "svchost.exe acessou a internet". O analista fechou porque "svchost é do Windows". Só faltou conferir caminho, comando, serviço hospedado, destino, conta e processo pai. Nome de executável sozinho não absolve ninguém.

3.3 Processos, linhas de comando e árvores

Uma árvore de processos mostra a cadeia de criação, não necessariamente a intenção. Normalmente, `explorer.exe` inicia aplicações do usuário; `services.exe` está ligado à gestão de serviços; `taskeng.exe` ou processos modernos do agendador podem lançar tarefas; `winword.exe` iniciando um shell exige contexto.

Campo	Interpretação / cuidado
Image	Nome e caminho do binário; nomes podem ser imitados
CommandLine	Argumentos; pode estar vazio se a política não registrar
ParentImage	Pai observado; processos legítimos também podem iniciar código suspeito
User	Conta executora; não confundir com autor humano
ProcessGuid	Identificador do Sysmon útil além do PID
IntegrityLevel	Contexto de integridade; não equivale sozinho a privilégio efetivo
Hashes	Identificação de arquivo; reputação não substitui análise de comportamento

Exemplo SIMULADO: cadeia que merece apuração

```
OUTLOOK.EXE -> WINWORD.EXE -> powershell.exe -> rundll32.exe
Usuário: EMPRESA\ana | Host: FIN-WS17
Origem do documento: anexo recebido por e-mail
```

O que o N1 faz: confirma se essa árvore aconteceu, recupera a linha de comando e a origem do documento, verifica conexões e arquivos gerados, compara com o EDR e preserva horários. **O que não faz:** afirmar "malware confirmado" só porque PowerShell apareceu.

Event ID 4688: criação de processo

O Security 4688 depende da política de auditoria de criação de processo; a inclusão da linha de comando requer configuração própria. Eventos podem trazer New Process Name, Creator Process Name, Process ID e Subject Logon ID, mas os campos mudam conforme versão e configuração. O Sysmon Event 1, se implantado, frequentemente fornece contexto adicional.

```
Get-WinEvent -FilterHashtable @{LogName="Security"; Id=4688; StartTime=(Get-Date).AddDays(-1)}
-MaxEvents 20 |
  Select-Object TimeCreated, Id, Message
```

MOMENTO SOC

"cmd.exe foi executado" não é incidente. "Word abriu cmd, que iniciou PowerShell com comando ofuscado, seguido de conexão externa não explicada" já é uma hipótese investigável. Evidência, sequência e contexto fazem a diferença.

Os exemplos de log deste módulo são SIMULADOS e simplificados para ensino. Campos e payload variam entre versões do Windows, políticas de auditoria e produtos; não substituem o XML original. Endereços .example e faixas reservadas a documentação são fictícios.

Exemplo A: criação de processo (Sysmon 1) *(simulado)*

```
UtcTime: 2026-10-24 12:14:33.000
Computer: FIN-WS17
EventID: 1
Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
ParentImage: C:\Program Files\Microsoft Office\root\Office16\WINWORD.EXE
User: EMPRESA\ana
ProcessGuid: {11111111-2222-3333-4444-555555555555}
CommandLine: powershell.exe -NoProfile -File C:\Users\ana\Documents\relatorio.ps1
```

Interpretação N1: Fato: Word iniciou PowerShell com script local. Não há, por este evento isolado, prova do conteúdo do script ou dano. Conferir arquivo, origem do documento, 4104, mudanças e conexões.

Leitura de SOC: processos e árvore de execução

Pergunta	Leitura de SOC
Onde observo?	4688, Sysmon 1, EDR
O que procuro?	Processo filho de aplicação Office ou navegador com argumento incomum
O que pode ser benigno?	Instalador corporativo ou macro homologada durante manutenção
O que pode ser suspeito?	Office iniciando shell, sequência de scripts ofuscados e conexão externa
Próximo passo N1	Colete ProcessGuid, imagem completa, pai, linha de comando, hash, usuário, horário e ações posteriores
Quando escalo?	Script de origem externa executado com efeitos não explicados, especialmente em ativo crítico

3.4 Serviços e drivers

Serviços do Windows podem iniciar automaticamente no boot, sob contas de sistema ou de serviço. São necessários para operação normal, mas o mecanismo também pode ser abusado para persistência ou execução remota. Drivers operam com privilégios elevados: alertas envolvendo carregamento de driver não autorizado exigem cuidado especial.

Evento / fonte	O que indica	Limitação
System 7045	Um serviço foi instalado	Não prova que executou ou seja malicioso

Evento / fonte	O que indica	Limitação
Security 4697	Instalação de serviço, se auditada	Nem sempre habilitado
System 7036	Mudança de estado do serviço	Rotina de operação gera grande volume
Sysmon 6	Carregamento de driver, se configurado	Cobertura depende de versão e configuração

```
Get-CimInstance Win32_Service | Select Name, State, StartMode, StartName, PathName
Get-WinEvent -FilterHashtable @{LogName="System"; Id=7045; StartTime=(Get-Date).AddDays(-7)}
```

Valide nome, ImagePath, assinatura, conta, horário de criação, chamado de mudança e atividade posterior. Um serviço com executável em diretório temporário é um sinal para investigar, não uma condenação automática.

Exemplo B: serviço instalado (System 7045) *(simulado)*

```
TimeCreated: 2026-10-24T02:31:10-03:00
Computer: APP-SRV02
EventID: 7045
ServiceName: AtualizadorERP
ImagePath: C:\Program Files\EmpresaERP\updater.exe
ServiceType: user mode service
StartType: auto start
AccountName: LocalSystem
```

Interpretação N1: Fato: houve registro de instalação do serviço. Validar mudança aprovada, arquivo e execução posterior; 7045 sozinho não comprova malware.

Leitura de SOC: serviços e drivers

Pergunta	Leitura de SOC
Onde observo?	System 7045/7036, Security 4697, Sysmon 6
O que procuro?	Serviço recente, ImagePath, StartName, mudança de estado
O que pode ser benigno?	Agente de backup, implantação ou atualização com change aprovado
O que pode ser suspeito?	Serviço desconhecido apontando para pasta gravável pelo usuário e executando fora da janela
Próximo passo N1	Compare chamado, executável assinado, proprietário, conta e telemetria de execução
Quando escalo?	Serviço ou driver não autorizado associado a execução/alteração de controles

3.5 Registro do Windows

O Registro armazena configurações do sistema e do usuário. Algumas chaves orientam inicialização automática; outras modificam políticas de segurança. Hives importantes incluem HKLM, HKCU, HKU e HKCR. HKCU representa a visão do usuário em contexto, não uma máquina inteira.

Local	Uso comum	Leitura no SOC
`HKCU\Software\Microsoft\Windows\CurrentVersion\Run`	Inicialização por usuário	Persistência possível, mas aplicativos legítimos usam
`HKLM\Software\Microsoft\Windows\CurrentVersion\Run`	Inicialização da máquina	Verificar executável, assinatura e mudança
`HKLM\SYSTEM\CurrentControlSet\Services`	Configuração de serviços/drivers	Alteração pode mudar execução no boot
Políticas do Defender / firewall	Configuração de controles	Mudanças devem ser correlacionadas a alterações aprovadas

Auditoria de mudança de chave não é universal. Sysmon 12, 13 e 14, quando configurados, cobrem determinados eventos de Registro. Security 4657 depende de auditoria adequada e SACL aplicável. Nunca assuma que ausência de evento significa chave intacta.

```
reg query "HKCU\Software\Microsoft\Windows\CurrentVersion\Run"
reg query "HKLM\Software\Microsoft\Windows\CurrentVersion\Run"
```

> **DICA**
>
> Não apague uma chave suspeita "para testar". Em SOC N1, registre o caminho, exporte evidências conforme o procedimento e encaminhe para a contenção autorizada. Alterar o Registro pode destruir evidência ou interromper o negócio.

Leitura de SOC: Registro

Pergunta	Leitura de SOC
Onde observo?	Sysmon 12/13/14, Security 4657
O que procuro?	Alteração de Run, serviços ou política de proteção
O que pode ser benigno?	Instalação de software e mudanças de GPO autorizadas
O que pode ser suspeito?	Alteração não explicada de inicialização ou redução de proteção
Próximo passo N1	Registre caminho, valor anterior se disponível, processo modificador e arquivos associados
Quando escalo?	Persistência ou desabilitação de controles com indícios corroborados

3.6 Tarefas agendadas

O Task Scheduler executa comandos por calendário, evento, inicialização ou logon. Atualizadores, backups, monitoramento e atacantes usam o mesmo recurso. Inspecione nome, autor, gatilho, ação, usuário executante e histórico.

Fonte	Sinal
Security 4698 / 4702	Tarefa criada / atualizada quando auditoria apropriada está habilitada
Microsoft-Windows-TaskScheduler/Operational	Eventos operacionais, inclusive execução e conclusão, quando disponível
EDR / Sysmon 1	Processos criados pela tarefa e seus efeitos

```
Get-ScheduledTask | Select TaskName,TaskPath,State
Get-ScheduledTaskInfo -TaskName "NOME_DA_TAREFA"
Get-WinEvent -LogName "Microsoft-Windows-TaskScheduler/Operational" -MaxEvents 25
```

Exemplo: tarefa "AtualizacaoPDF" executando binário dentro de AppData a cada 5 minutos. Compare com software instalado, usuário, criação recente, política interna e destino de rede. Nada de excluir sem procedimento.

Exemplo D: tarefa criada (Security 4698) *(simulado)*

```
TimeCreated: 2026-10-24T11:07:02-03:00
Computer: LAB-WS01
EventID: 4698
SubjectUserName: estagiario
TaskName: \RelatorioMensal
TaskContent:
<Actions><Exec><Command>C:\ProgramData\Relatorios\gerador.exe</Command></Exec></Actions>
```

Interpretação N1: Fato: tarefa registrada como criada. O exemplo é recorte didático do XML; consultar TaskContent completo, usuário executante, trigger, assinatura e contexto.

Leitura de SOC: tarefas agendadas

Pergunta	Leitura de SOC
Onde observo?	4698/4702, TaskScheduler Operational, Sysmon 1
O que procuro?	Tarefa nova, gatilho, conta executora, ação e periodicidade
O que pode ser benigno?	Atualizador, backup, tarefa de domínio planejada
O que pode ser suspeito?	Execução recorrente de binário em AppData/Temp por conta inesperada
Próximo passo N1	Compare XML da tarefa, horário, processo lançado, mudança e endpoint
Quando escalo?	Tarefa não autorizada associada à execução suspeita

Persistência: serviço, tarefa e chave Run lado a lado

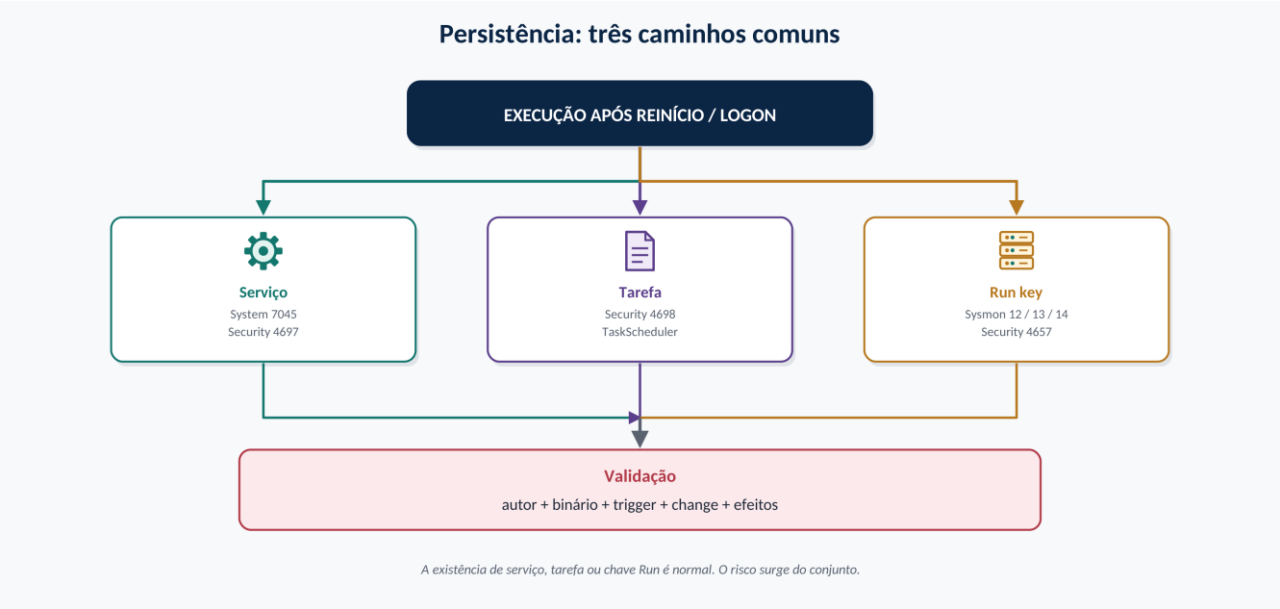


Figura 3.2: Persistência: três caminhos comuns

Como ler: a existência de serviço, tarefa ou chave Run é normal. O risco surge do conjunto: criação fora de padrão, binário suspeito, conta inesperada e ações posteriores.

3.7 PowerShell e scripts

PowerShell é ferramenta padrão de administração e automação. Ataques frequentemente se aproveitam dela porque já está disponível no sistema. Comportamentos relevantes incluem execução de código em memória, scripts ofuscados, mudanças de política e download seguido de execução. O objetivo é compreender a cadeia, não bloquear a palavra PowerShell.

Fonte	Uso	Pré-requisito / limite
PowerShell Operational 4104	Conteúdo de script blocks	Script Block Logging conforme política; cobertura varia
PowerShell Operational 4103	Invocação de módulos / detalhes de pipeline	Module Logging habilitado e módulos pertinentes
Security 4688 / Sysmon 1	Processo e argumentos	Auditoria e coleta de linha de comando
AMSI / EDR	Inspeção e detecções de conteúdo	Depende de integração e proteção efetiva

```
Get-WinEvent -FilterHashtable @{LogName="Microsoft-Windows-PowerShell/Operational"; Id=4104;
  StartTime=(Get-Date).AddDays(-1)} -MaxEvents 20
```

Exemplo didático de triagem: um script administrativo consulta eventos locais e escreve CSV numa pasta aprovada. Outro inicia por documento Office, usa parâmetros ofuscados e abre comunicação com destino externo raro. A diferença está em origem, finalidade, autorização e efeitos observados.

> **O QUE UM N1 REALMENTE PRECISA SABER**

> "ExecutionPolicy Bypass" não prova invasão. A Execution Policy não é uma fronteira de segurança. É uma pista entre várias. O que importa é a linha completa de execução, seu contexto e as ações posteriores.

Exemplo E: PowerShell script block (4104) *(simulado)*

```
Computer: LAB-WS01
EventID: 4104
ScriptBlockText: Get-Process | Select-Object Name, Id | Export-Csv C:\Temp\processos.csv -
NoTypeInformation
Path: C:\Scripts\inventario.ps1
```

Interpretação N1: Fato: trecho de script registrado, se Script Block Logging estiver habilitado. A ação é compatível com inventário benigno, mas verificar origem e autorização.

Leitura de SOC: PowerShell

Pergunta	Leitura de SOC
Onde observo?	4103/4104, 4688, Sysmon 1, EDR/AMSI
O que procuro?	Origem do script, argumentos, blocos registrados e efeitos
O que pode ser benigno?	Inventário, administração e automação aprovados
O que pode ser suspeito?	Documento externo iniciando comando ofuscado e download seguido de execução
Próximo passo N1	Recupere cadeia, bloco disponível, autenticação, DNS/rede e arquivos
Quando escalo?	Execução suspeita com efeitos, desvio de baseline ou alvos críticos

3.8 WMI e execução remota

WMI (Windows Management Instrumentation) oferece consultas e gerenciamento, local ou remoto. É usado por inventário, suporte, ferramentas de monitoramento e automação. Seu abuso pode aparecer como execução remota ou persistência por assinaturas de eventos. WinRM e PowerShell Remoting são outros canais administrativos, não sinônimos de WMI.

Sinal	Interpretação
`WmiPrvSE.exe` com filho inesperado	Verificar origem da chamada, usuário e processo criado
Microsoft-Windows-WMI-Activity/Operational	Erros e operações de WMI, conforme eventos disponíveis
Sysmon 19, 20 e 21	Eventos associados a filtros/consumidores/bindings de WMI, se configurados
Conexão remota com origem incomum	Correlacionar autenticação, execução e mudança em destino

Um inventário corporativo pode produzir dezenas de chamadas WMI; isso é esperado. Já a execução a partir de estação de usuário para múltiplos servidores fora do padrão exige correlação com autorização e telemetria dos alvos.

Leitura de SOC: WMI / WinRM

Pergunta	Leitura de SOC
Onde observo?	WMI-Activity Operational, Sysmon 19/20/21, 4688, EDR
O que procuro?	Processo WmiPrvSE.exe, subscrição de evento, host de origem
O que pode ser benigno?	Ferramentas de inventário e gestão remota
O que pode ser suspeito?	Estação de usuário iniciando execução em vários servidores sem justificativa
Próximo passo N1	Cruze host origem/destino, autenticação, processo filho e conta
Quando escalo?	Execução remota anômala ou assinatura persistente sem autorização

3.9 Autenticação, RDP e SMB

O Windows registra eventos de autenticação no host de destino e, em alguns cenários, no controlador de domínio. A distinção entre "tentou", "autenticou" e "estabeleceu sessão interativa" evita relatórios errados. Uma conta pode autenticar para acessar um compartilhamento sem abrir área de trabalho.

Evento	Interpretação essencial
4624	Logon bem-sucedido no computador que registrou o evento; verificar Logon Type
4625	Falha de logon; olhar status/substatus, conta e origem
4634 / 4647	Encerramento de sessão / logoff iniciado pelo usuário
4648	Uso de credenciais explícitas em certos cenários
4672	Privilégios especiais atribuídos a uma nova sessão; não equivale a comprometimento
4776	Validação NTLM, frequentemente no sistema autenticador
4768 / 4769 / 4771	Eventos Kerberos nos DCs; aprofundamento no Módulo 8
5140 / 5145	Acesso a compartilhamento / checagem detalhada quando auditados

Tipos de logon que aparecem todo dia

Tipo	Significado usual	Cuidado
2	Interativo local	Não significa RDP
3	Rede (SMB, acesso remoto a recurso etc.)	Não prova login gráfico
4	Batch	Pode ser tarefa agendada
5	Service	Execução de serviço
7	Unlock	Desbloqueio da sessão
10	RemoteInteractive (frequente no RDP)	Exigir contexto e origem
11	CachedInteractive	Autenticação com credenciais em cache

RDP costuma envolver Type 10 no destino, mas investigações podem precisar de canais TerminalServices e eventos adicionais. SMB normalmente gera Type 3 e, com a auditoria adequada, eventos de compartilhamento. A conexão de rede à porta 3389 ou 445, sozinha, não garante sessão concluída.

```
Get-WinEvent -FilterHashtable @{LogName="Security"; Id=4624,4625; StartTime=(Get-
Date).AddHours(-6)} -MaxEvents 50 |
  Select TimeCreated, Id, Message
```

> **NA VIDA REAL**
>
> O ticket dizia "RDP confirmado no servidor". A única evidência era um allow TCP/3389 no firewall. Isso comprova trânsito autorizado de rede, não autenticação nem sessão remota. Procure logon no destino e telemetria TerminalServices.



Figura 3.3: O erro de confundir rede com sessão

Como ler: o log de firewall comprova a decisão/fluxo que o sensor registrou. A sessão RDP precisa de registros do destino e contexto de autenticação; conexão à porta, isoladamente, é insuficiente.

Exemplo C: logon no Windows (Security 4624) *(simulado)*

```
TimeCreated: 2026-10-24T03:02:04-03:00
Computer: APP-SRV02
EventID: 4624
TargetUserName: adm_erp
LogonType: 10
IpAddress: 10.50.20.17
TargetLogonId: 0x25e7f
```

Interpretação N1: Fato: logon RemoteInteractive bem-sucedido registrado no destino. Verificar se origem é jump server, quais processos foram iniciados e se houve aprovação.

Leitura de SOC: RDP e SMB

Pergunta	Leitura de SOC
Onde observo?	4624/4625, TerminalServices, 5140/5145, firewall
O que procuro?	Tipo de logon, origem, destino, compartilhamento e resultados
O que pode ser benigno?	Acesso por bastion autorizado e backup usando compartilhamento
O que pode ser suspeito?	Conta privilegiada por Type 10 fora do bastion; acesso SMB em massa
Próximo passo N1	Associe Logon ID, horário, conta, jump server, ticket e eventos de arquivo
Quando escalo?	Acesso privilegiado anômalo, movimento lateral comprovado ou leitura sensível

3.10 Event Viewer e canais de log

O Event Viewer organiza canais por função. Security registra eventos de auditoria; System, estado e serviços; Application, aplicações; `Microsoft-Windows-*/Operational`, componentes específicos. O registro de um evento depende de fonte, configuração, retenção, saúde do agente e encaminhamento.

Canal	Para que serve
Windows Logs / Security	Autenticações, privilégios, criação de processos e auditorias habilitadas
Windows Logs / System	Serviços, drivers, falhas e alterações operacionais
Windows Logs / Application	Erros e eventos de aplicações
PowerShell / Operational	Atividade de scripts conforme logging
TaskScheduler / Operational	Histórico operacional do agendador
TerminalServices-*	Sessões e operações de acesso remoto
Sysmon / Operational	Telemetria adicional se Sysmon estiver instalado

O relógio merece uma investigação própria

O horário exibido pode estar convertido do UTC; logs exportados, SIEM e EDR podem usar fusos diferentes. Documente timezone e precisão. Correlação de dois eventos com o mesmo segundo não garante causalidade; use identificadores, host, Logon ID, GUID e relação processo-pai.

Se um evento esperado não aparece: verifique se a fonte o produz, se a auditoria estava ativa, se há retenção, se o log girou, se o sensor estava operacional e se o pipeline até o SIEM funcionou. "Sem resultados" pode ser simplesmente "sem visibilidade".

3.11 Sysmon e visibilidade de endpoint

Sysmon (System Monitor), do pacote Sysinternals da Microsoft, registra telemetria detalhada de sistema conforme sua configuração. Não bloqueia ataques por si só, não substitui EDR e não coleta automaticamente todos os tipos de evento. A configuração é determinante para volume e cobertura.

Sysmon ID	Categoria	Pergunta útil
1	Process Create	Que processo, pai e argumentos?
3	Network Connection	Qual processo iniciou a conexão, se a coleta estiver habilitada?
6	Driver Loaded	Que driver foi carregado?
7	Image Loaded	Que módulo foi carregado? Pode gerar muito volume
11	File Create	Que arquivo foi criado?
12, 13 e 14	Registry	Que evento de Registro foi monitorado?
19, 20 e 21	WMI Events	Que assinatura permanente WMI foi registrada?
22	DNS Query	Qual processo consultou o nome?
23 / 26	File Delete	O que foi removido conforme configuração/versão?

```
Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational" -MaxEvents 10
Get-WinEvent -FilterHashtable @{LogName="Microsoft-Windows-Sysmon/Operational"; Id=1;
StartTime=(Get-Date).AddDays(-1)} -MaxEvents 20
```

Boa prática: confirme esquema, versão e configuração do Sysmon antes de interpretar campos. Coletar tudo sem planejamento pode gerar alto volume; reduzir demais pode eliminar a evidência que o SOC precisava.

Exemplo F: consulta DNS (Sysmon 22) *(simulado)*

```
Computer: FIN-WS17
EventID: 22
Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
QueryName: atualizacao.empresa.example
QueryStatus: 0
```

Interpretação N1: Fato: consulta DNS observada e associada ao processo; não comprova conexão TCP, download, C2 ou exfiltração.

Leitura de SOC: Event Viewer e Sysmon

Pergunta	Leitura de SOC
Onde observo?	Security, System, Operational e Sysmon
O que procuro?	Saúde do canal, retenção, configuração, timestamps, campos presentes
O que pode ser benigno?	Ausência de Sysmon em estação onde nunca foi instalado
O que pode ser suspeito?	Lacuna de cobertura justamente em dispositivo/intervalo suspeito
Próximo passo N1	Verifique auditoria, política, tamanho, agente de forwarding e defasagem
Quando escalo?	Perda relevante de telemetria durante investigação prioritária

3.12 Método de triagem Windows: do alerta à decisão

1. **Congele a descrição do alerta:** regra, fonte, primeiro e último horário, host e usuário.

2. **Valide saúde e cobertura:** existe EDR? Sysmon? 4688? logging de PowerShell? Há atraso ou perda?
3. **Reconstrua a árvore e a sessão:** ProcessGuid/PID, pai, linha de comando, usuário e Logon ID.
4. **Busque efeitos:** arquivos, Registro, serviços, tarefas, DNS, rede e mudanças de privilégio.
5. **Contextualize:** papel do equipamento, software homologado, janela de mudança, padrão histórico.
6. **Classifique com precisão:** tentativa, execução, persistência ou impacto comprovado; não confunda.
7. **Registre** evidências, limitações, hipótese e próximos passos. Escalone por impacto e playbook.

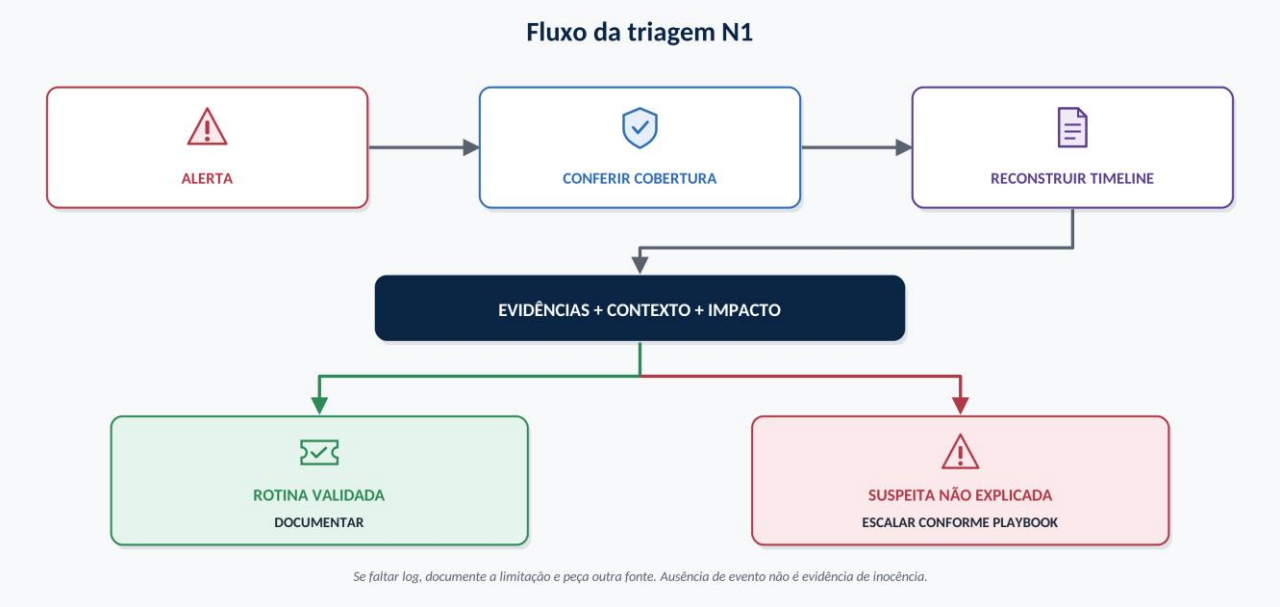


Figura 3.4: Fluxo da triagem N1

Como ler: se faltar log, documente limitação e peça outra fonte. Não converta ausência de evento em evidência de inocência.

Campo do ticket	Exemplo de boa escrita
Fato	Em FIN-WS17, winword.exe iniciou powershell.exe às 09:14:33 -03, evento EDR X
Contexto	Usuária recebeu documento por e-mail pouco antes; mudança não identificada
Corroboração	Sysmon 1 confirmou cadeia; proxy registrou conexão HTTPS subsequente
Limitação	Script Block Logging não disponível; não é possível afirmar conteúdo integral do script
Avaliação	Execução suspeita com comunicação externa; comprometimento ainda em apuração
Ação	Escalado N2 para contenção conforme playbook; evidências anexadas

MOMENTO SOC

Nunca confunda prioridade alta com liberdade para agir sem autorização. Isolar um controlador de domínio, derrubar um ERP ou desativar uma conta de serviço pode provocar indisponibilidade maior que o alerta.

3.13 Três mini-casos de plantão

Caso 1: "Word abriu PowerShell"

Às 09:14, um EDR alerta que WINWORD.EXE iniciou powershell.exe. O documento foi aberto a partir de anexo externo; a linha de comando contém conteúdo ofuscado. Às 09:15 aparece consulta DNS e conexão HTTPS para um domínio desconhecido. O proxy registra resposta 200, mas não há arquivo comprovadamente baixado.

Triagem: confirmar cadeia no EDR/Sysmon, origem do anexo, reputação contextual do destino, downloads, arquivos, tarefa/Registro e histórico do usuário. **Conclusão adequada:** comportamento de execução suspeito com comunicação subsequente; não afirmar exfiltração nem payload executado sem evidência correspondente.

Caso 2: "Serviço instalado em servidor"

System 7045 aponta serviço novo às 02:31 num servidor de aplicação. O ImagePath aponta para diretório de software corporativo; o mesmo horário coincide com deploy aprovado. O binário tem assinatura válida, e logs de implantação corroboram a alteração.

Triagem: verificar chamado, conta, caminho e execução; comparar com baseline. **Classificação provável:** alteração administrativa legítima, com evidências anexadas. Assinatura e change isolados não bastariam se houvesse comportamento anormal adicional.

Caso 3: "Conta privilegiada entrou por RDP"

Security 4624 Type 10 às 03:02 em servidor crítico; origem é estação de uso geral e não o jump server documentado. A conta pertence ao grupo de administração; não existe alteração aprovada identificada. Minutos depois, uma tarefa foi criada.

Triagem: correlacionar Logon ID, origem, 4698, processos e console de acesso remoto; confirmar se atividade é autorizada. **Prioridade alta** pela combinação privilégio + desvio de arquitetura + possível persistência.

3.14 Laboratório guiado: estação de análise Windows

> **LABORATÓRIO: Ambiente**
>
> VM Windows 10/11 ou Windows Server de laboratório com privilégios administrativos apenas quando necessário. Use uma máquina própria/autorizada, preferencialmente isolada. Este laboratório é de observação; não há execução de payload ofensivo, persistência maliciosa nem mudanças de segurança.

Preparação

1. Crie snapshot/checkpoint da VM e registre data, timezone, versão do Windows e hostname.
2. Abra Event Viewer e identifique os canais Security, System e PowerShell Operational.
3. Verifique com o administrador do laboratório quais políticas de auditoria estão ativas; não presuma 4688/4104.
4. Se o Sysmon já estiver instalado, identifique versão/configuração. A instalação é opcional e requer autorização.

Atividade A: árvore de processo benigna

Abra o Bloco de Notas pelo menu Iniciar e identifique seu processo. Compare Task Manager/Details com PowerShell. Depois, feche o programa e observe diferenças entre estado atual e registro histórico de eventos.

```
Get-Process notepad -ErrorAction SilentlyContinue | Select Name,Id,Path,StartTime
Get-CimInstance Win32_Process -Filter "name = 'notepad.exe'" | Select
ProcessId,ParentProcessId,CommandLine,ExecutablePath
```

Resultado esperado: um processo notepad.exe visível em execução, com PID. O pai pode variar conforme versão e método de abertura. Se não houver Event 4688, registre a lacuna em vez de inventar o evento.

Atividade B: serviço e tarefa legítimos

```
Get-Service | Select -First 15 Name,Status,StartType
Get-ScheduledTask | Select -First 15 TaskName,TaskPath,State
```

Escolha um serviço e uma tarefa conhecidos; documente proprietário, finalidade, caminho/ação e usuário. Não altere nem remova objetos do sistema.

Atividade C: linha do tempo

Colete 3 eventos recentes dos canais disponíveis, normalize os horários e monte uma tabela contendo timestamp, host, fonte, ID, descrição, correlação e confiança. Se algum canal estiver ausente, explique qual hipótese ficou sem teste.

Hora (-03)	Fonte / ID	Observação	Limitação
10:01:12	Security / 4624	Logon no host de lab	Requer tipo e origem
10:02:05	Sysmon / 1	Execução do app de teste	Disponível só se configurado
10:03:10	System / 7036	Serviço mudou de estado	Pode ser rotina normal

Atividade D: exercício de ticket

Cenário simulado: às 11:07 o SIEM sinalizou criação de tarefa "RelatorioMensal" no host LAB-WS01. O criador é `LAB\estagiario`; a ação aponta para `C:\ProgramData\Relatorios\gerador.exe`; não existe alerta EDR correlacionado. Redija em 8 linhas: fato, lacunas, hipótese, validação necessária, criticidade e decisão. Não conclua "falso positivo" só porque o EDR ficou em silêncio.

Laboratório E: diferenciar tentativa de sucesso

Objetivo e procedimento: em VM própria, consulte registros Security 4624 e 4625 existentes; organize por Logon Type, conta, origem e resultado. Não gere tentativas de força bruta.

```
Get-WinEvent -FilterHashtable @{LogName="Security";Id=4624,4625;StartTime=(Get-Date).AddDays(-
1)} -MaxEvents 40 | Select TimeCreated,Id,Message
```

Entrega esperada: quadro separando falha, sucesso, logon local e autenticação de rede; registrar ausência se auditoria indisponível.

Laboratório F: inventário de autoexecução sem alterar nada

Objetivo e procedimento: em VM própria, consulte duas chaves Run, tarefas e serviços; anote executáveis, editor, usuário e finalidade sem excluir objetos.

```
reg query "HKCU\Software\Microsoft\Windows\CurrentVersion\Run"
Get-ScheduledTask | Select -First 10 TaskName,TaskPath,State
Get-CimInstance Win32_Service | Select -First 10 Name,StartMode,PathName
```

Entrega esperada: tabela com três entradas legítimas e justificativas, indicando o que seria necessário para suspeita.

Laboratório G: visibilidade e perda de dados

Objetivo e procedimento: liste canais do Windows, confira volume/estado de auditoria e se existe Sysmon. Não ative políticas sem aprovação.

```
Get-WinEvent -ListLog Security,System,Application | Select
LogName,IsEnabled,RecordCount,MaximumSizeInBytes
auditpol /get /category:*
```

Entrega esperada: matriz com disponível/ausente, dependência e hipótese que ficou impossível confirmar.

Laboratório H: correlação de rede por processo

Objetivo e procedimento: abra aplicativo comum (navegador de lab) e consulte conexões locais. Mapeie PID ao processo, observando que conexões podem terminar antes da consulta.

```
Get-NetTCPConnection -State Established | Select -First 20
LocalAddress,LocalPort,RemoteAddress,RemotePort,OwningProcess
Get-Process | Select Name,Id,Path
```

Entrega esperada: mini-timeline com PID, processo, conexão e ressalva sobre volatilidade/ausência de histórico.

Laboratório I: construa e revise um ticket

Objetivo e procedimento: use o cenário simulado: tarefa criada por usuário padrão em estação; sem Sysmon e com EDR sem alerta. Produza ticket separando fato e hipótese.

```
Campos: fonte | tempo e fuso | host | conta | objeto | evidências | lacunas | hipótese |
validação | escalonamento
```

Entrega esperada: ticket auditável sem afirmar "ataque" ou "falso positivo" antes da validação.

> **LABORATÓRIO: Regras do laboratório**
>
> Somente equipamentos próprios ou autorizados. Faça snapshot, preserve eventos e não desative controles. Treinar análise não exige produzir malware nem comprometer a máquina.

3.15 Consultas e comandos para ter à mão

Objetivo	Comando / ferramenta
Eventos recentes	`Get-WinEvent -ListLog *` / `Get-WinEvent -FilterHashtable`
Processos	`Get-Process` / `Get-CimInstance Win32_Process`
Serviços	`Get-CimInstance Win32_Service`
Tarefas	`Get-ScheduledTask` / `Get-ScheduledTaskInfo`
Rede local	`Get-NetTCPConnection` / `Get-DnsClientCache`
Política de auditoria	`auditpol /get /category:*`
Contas e sessões	`whoami /all` / `quser` (quando aplicável)
Registro	`reg query` (consulta de leitura)
Autoruns	Sysinternals Autoruns, se autorizado
Process Explorer	Sysinternals Process Explorer, se autorizado

Guia de referências oficiais: Microsoft Learn (Windows Event Log, Advanced Audit Policy, PowerShell logging, Task Scheduler), Microsoft Sysinternals (Sysmon, Autoruns e Process Explorer), MITRE ATT&CK (técnicas de execução e persistência). Confirme os pré-requisitos da versão instalada antes de aplicar qualquer configuração.

3.16 Erros comuns e falsos positivos

- Tratar um 4625 como login bem-sucedido, ou Type 3 como sessão RDP.
- Afirmar que PowerShell é malware; ele também é ferramenta comum de administração.
- Confundir 7045 com execução confirmada do serviço.
- Assumir que ausência de 4104, 4688 ou Sysmon 3 significa ausência da ação.
- Esquecer fuso, NAT, reutilização de PID, contas compartilhadas e alterações aprovadas.
- Ignorar que softwares de gestão podem usar WMI, tarefas e contas SYSTEM.
- Desativar serviço, deletar tarefa, matar processo ou isolar servidor crítico sem autorização.

Falsos positivos: sinais e como confirmar

Alerta	Possível explicação legítima	Como confirmar antes de encerrar
PowerShell fora de horário	Job automatizado	Correlacionar conta, agendador, comando, proprietário e change
Serviço novo 7045	Deploy de agente	Conferir ticket, pacote, assinatura, conta e execução posterior
WmiPrvSE.exe acionou processo	Inventário de TI	Validar console de gestão, host de origem e frequência histórica
Novo item em Run	Aplicação configurando startup	Identificar instalador, executável, assinatura e aceite
Muitos 4625	Senha antiga em serviço	Checar status/substatus, conta, hosts, mudança de senha e padrão

Alerta	Possível explicação legítima	Como confirmar antes de encerrar
4624 Type 3 de madrugada	Backup em compartilhamento	Comparar identidade técnica, origem, schedule e arquivos
Muitas conexões SMB	Distribuição de software	Confirmar ferramenta, change, destinatários e volume
Tarefa agendada criada	Software atualizando componentes	Verificar XML completo, ação, conta, horário e evidência do fabricante
Binário Microsoft em execução	Componente do Windows	Conferir caminho, assinatura, argumentos, pai e destinos
Sysmon DNS para domínio raro	Software de proteção / telemetria	Checar processo, fornecedor, baseline e resposta de rede

> **NA VIDA REAL**
>
> "É Microsoft, pode fechar." A Microsoft fornece excelentes componentes. O atacante agradece quando o analista deixa de conferir como eles foram usados.

Quando escalar imediatamente

Sinais combinados envolvendo privilégio elevado, movimentação entre máquinas, criação de persistência não explicada, execução a partir de documentos suspeitos, tentativa de desligar controles, possível ransomware ou acesso a ativos Tier 0. A classificação final segue impacto, confiança, criticidade do ativo, SLA e procedimentos do SOC.

Fechamento do Módulo 3

Exercícios de fixação

1. Uma conexão TCP/3389 aceita pelo firewall comprova RDP autenticado? Justifique.
2. Quais dados devem acompanhar uma suspeita de processo criado por documento Office?
3. Por que um 7045 não confirma, sozinho, serviço malicioso em execução?
4. Explique a diferença entre Security 4688 e Sysmon Event 1.
5. Um 4624 Type 3 significa que o usuário abriu área de trabalho?
6. O que fazer quando você procura 4104 e não encontra nenhum evento?
7. Dê três explicações benignas para uma tarefa agendada recém-criada.
8. Qual o problema de investigar somente PID sem horário/host/ProcessGuid?
9. Uma assinatura digital válida encerra um alerta? Por quê?
10. Que evidências cruzaria para investigar RDP privilegiado fora do jump server?
11. Qual a diferença entre fato observado, hipótese e lacuna de telemetria?
12. Uma estação faz consultas DNS para um domínio e não há log de rede; qual conclusão é sustentada?
13. Um 4624 Type 3 apareceu num servidor de arquivos. O ticket pode afirmar acesso RDP?
14. Serviço foi instalado no horário de deploy. O caso está encerrado?
15. Sysmon 22 mostra consulta DNS para destino desconhecido. Houve C2?
16. PID 4200 aparece em eventos de dois dias distintos. É o mesmo processo?
17. Event ID 4698 registra nova tarefa. Qual a primeira checagem?
18. N1 encontra chave Run desconhecida. Deve apagá-la?
19. Firewall mostra allow TCP 3389. O que isso prova?
20. O EDR ficou sem alertar após PowerShell. Isso prova benignidade?

Entrevista: resposta fraca x resposta boa

P: O que você vê primeiro num PowerShell suspeito?

Resposta fraca	Resposta boa
Bloqueio o PowerShell.	Eu verifico árvore de processos, usuário, linha de comando, script disponível, origem e efeitos; depois avalio autorização e impacto.

P: Como distingue serviço legítimo de persistência?

Resposta fraca	Resposta boa
Olho se o serviço tem nome estranho.	Consulto 7045, ImagePath, conta, assinatura, horário, aprovação, execução posterior e baseline; nenhum campo sozinho decide.

P: O que significa Type 10?

Resposta fraca	Resposta boa
Alguém acessou o servidor pela porta 3389.	É logon RemoteInteractive registrado no destino, frequentemente RDP. Correlaciono origem e TerminalServices para caracterizar a sessão.

P: Como investiga suspeita de SMB lateral?

Resposta fraca	Resposta boa
Se apareceu 445, foi movimento lateral.	Relaciono autenticações Type 3, eventos 5140/5145, origem, destino, volume, serviço, processos e autorização; 445 sozinho não prova lateralidade.

P: Se não houver 4104, o que faz?

Resposta fraca	Resposta boa
O PowerShell não rodou.	Verifico configuração, versão, retenção e saúde da coleta. Busco EDR, 4688, Sysmon e outras fontes e documento a lacuna.

P: E se for um controlador de domínio?

Resposta fraca	Resposta boa
Eu isolaria imediatamente.	Escalaria com prioridade e evidências, seguindo playbook, pois isolar um DC sem autorização pode derrubar autenticação e serviços críticos.

P: Quando é falso positivo?

Resposta fraca	Resposta boa
Quando o antivírus não detectou.	Quando a atividade foi explicada por evidência corroborada e contexto legítimo; documento as verificações e limitações.

P: Como monta a timeline?

Resposta fraca	Resposta boa
Ordeno os alerts no SIEM.	Normalizo fuso, correlaciono host, Logon ID, ProcessGuid, ações de processo, arquivos, DNS/rede e preservo fontes e confiança.

P: Um 7045 significa execução?

Resposta fraca	Resposta boa
Sim, instalou e executou malware.	7045 indica instalação de serviço. Preciso de execução/estado/processo e evidência de maliciosidade para afirmações adicionais.

P: Uma assinatura válida elimina suspeita?

Resposta fraca	Resposta boa
Sim, é de fornecedor conhecido.	Não. Binários legítimos e assinados podem ser usados indevidamente. Contexto e comportamento pesam na análise.

Checklist de domínio

- ☐ Sei distinguir processo, thread, serviço, tarefa e Registro.
- ☐ Entendo PID, PPID e por que correlacionar GUID/horário.
- ☐ Conheço 4624, 4625, 4688, 4698, 7045 e suas limitações.
- ☐ Não confundo Type 3 com Type 10.
- ☐ Sei consultar Event Viewer e Get-WinEvent sem alterar evidências.
- ☐ Conheço o papel de Script Block Logging, WMI e Sysmon.
- ☐ Consigo justificar suspeita por cadeia e contexto, não por nome de programa.
- ☐ Sei produzir ticket com fato, hipótese, lacuna, próximo passo e escalonamento.

Checklist de prontidão operacional

- ☐ Consigo identificar o processo pai e o filho sem confundir PID com identidade duradoura.
- ☐ Distingo tentativa, autenticação, execução, persistência e impacto.
- ☐ Sei onde procurar 4688, 7045, 4698, 4624, 4104 e Sysmon sem presumir auditoria.
- ☐ Consigo documentar uma lacuna de coleta e propor outra fonte.
- ☐ Não encerro um alerta só por assinatura digital ou pelo nome do executável.
- ☐ Sei quando escalar risco privilegiado e quando não executar contenção autônoma.
- ☐ Entrego ticket com horário/fuso, fonte, evidências, interpretação e próximos passos.

Resumo do módulo

Um N1 que entende Windows não decora um catálogo e sai procurando todo ID em toda máquina. Ele entende o comportamento esperado, conhece os pontos de telemetria, monta sequências, mede a confiabilidade da evidência e respeita o impacto das ações. Processos, serviços, tarefas, Registro, PowerShell, WMI, RDP e SMB são ferramentas normais do ambiente; tornam-se suspeitos quando o contexto, a origem e os efeitos fogem do padrão.

> **NA VIDA REAL**
>
> A máquina não "ficou limpa" porque o SIEM não achou nada. O analista competente descobre primeiro se alguém estava olhando.

> **NA VIDA REAL: Fechamento**
>
> No Windows, um executável não usa crachá escrito "sou malicioso". O SOC investiga comportamento, contexto e evidência. Quem só decora Event ID vira catálogo; quem correlaciona vira analista.

Respostas comentadas

Exercício 1. Não. Mostra trânsito permitido; exige telemetria no destino para afirmar autenticação/sessão.

Exercício 2. Cadeia pai-filho, argumento, usuário, arquivo/anexo, origem, hora, rede, arquivos criados e controles.

Exercício 3. Registra instalação. Validar binário, execução, conta, autorização e comportamento.

Exercício 4. 4688 é auditoria nativa configurável; Sysmon 1 é telemetria adicional com campos como ProcessGuid conforme configuração.

Exercício 5. Não. Type 3 costuma indicar autenticação pela rede a recurso, como SMB.

Exercício 6. Verifique se logging está habilitado, versão, retenção, saúde da fonte e encaminhamento. Documente lacuna.

Exercício 7. Atualizador, backup, software de inventário, tarefa de manutenção/deploy autorizado.

Exercício 8. PID é reutilizado e pode mudar; sem contexto é fácil correlacionar processos distintos.

Exercício 9. Não. Binários assinados podem ser abusados; avalie cadeia, argumentos, comportamento e autorização.

Exercício 10. 4624 Type 10 no destino, TerminalServices, IP/origem, VPN, identidade, 4688/EDR, tarefas e change.

Exercício 11. Fato = registro verificável; hipótese = interpretação testável; lacuna = evidência indisponível.

Exercício 12. A consulta DNS pode ser afirmada na fonte que a registrou. Sem rede, conexão bem-sucedida não está provada.

Exercício 13. Não. Type 3 é logon de rede; identificar protocolo/compartilhamento e procurar registros de sessão se houver hipótese de RDP.

Exercício 14. Não automaticamente. Change e caminho são contexto forte, mas verificar efeitos posteriores, identidade do binário e desvios.

Exercício 15. Não comprovado. Consulta é evidência de resolução; cruzar com conexão, processo, recorrência e reputação do destino.

Exercício 16. Não necessariamente. PID pode ser reutilizado. Usar tempo de criação, host e ProcessGuid quando disponível.

Exercício 17. Nome, XML/ação, autor, usuário executor, gatilho, localização de binário e aprovação.

Exercício 18. Não. Preservar evidência e seguir contenção autorizada; remoção pode destruir rastros e impactar negócio.

Exercício 19. Uma decisão/fluxo de rede conforme o sensor. É necessário log do destino para confirmar autenticação/sessão.

Exercício 20. Não. Ausência de alerta não implica ausência de execução ou impacto. Verificar telemetria e cobertura.

Próximo módulo

Módulo 4: Linux para SOC: processos, permissões, systemd, cron, SSH, journald, bash, logs de autenticação e investigação de servidor Linux. Depois, **Módulo 5: Logs** e **Módulo 6: SIEM** aprofundam coleta, parsing, correlação e busca.

Trilha oficial: módulos 0 a 33 (34 módulos) + 3 seções especiais: Não Faça Isso no SOC; Frases que Todo N1 Vai Ouvir; Cheat Sheets.